CASE STUDY REPORT: FULLSTACK PRODUCT ENGINEER

AI Interview Platform Revamp (Steps 1 to 6) | Branch: feat/product-revamp | Seeded Fault Branch: test/seeded-fault-proof

1. Executive Summary & Deep Context / Domain Immersion (Step 2)

1.1 Product, Purpose & Architecture Overview

The AI Interview Platform is a multi-tenant B2B talent assessment system built with a Ruby on Rails 7 API (api/) and a React 18 + TypeScript + Vite SPA (web/). Unlike static multiple-choice tests or rigid one-way video recordings, the platform conducts live, adaptive, voice-to-voice behavioral and technical interviews powered by Google Gemini Live (BidiGenerateContent) over a full-duplex WebSocket bridge (AudioWebSocketMiddleware).

During an interview, a sidecar worker (CoverageAnalyzerWorker + Coverage::Analyzer) evaluates candidate turns after every response to track probing depth across configured B7 Competency Taxonomy skills (not_yet -> initiated -> partial -> covered) and dynamically injects updated probing guidance (Coverage::MapInjector) into the live AI session. Post-session, Portfolios::Generator synthesizes a structured Skill Portfolio (L1-L5 ratings, confidence levels, and verbatim evidence quotes), which assessors can review, override (AssessorOverride), export to PDF, and compare against job openings via FitGap::Engine.

1.2 Indonesian HRTech Industry Context, Users (Assessors) & Candidates (UU PDP No. 27/2022)

In Indonesia's high-volume hiring market (enterprise banking, BUMN, tech unicorns, and Tech-Enabled Services), recruitment teams screen hundreds to thousands of applicants per vacancy across variable network conditions (mobile 4G/tethering and corporate firewalls). Three domain imperatives govern production readiness:

1. Evidence Integrity for Assessors: An L1 rating must mean "demonstrated L1 behavior backed by transcript quotes" - never "the candidate disconnected early or time expired before the AI asked about this skill." Assessors also require preserved human overrides across portfolio regenerations and canonical skill_id matching when comparing Indonesian assessments against English job vacancies.

2. Candidate Fairness & UU PDP (Law No. 27/2022) Compliance: Biometric voice streams, camera proctoring feeds, and automated AI competency profiling constitute personal data processing under Indonesia's Personal Data Protection Law (UU No. 27 Tahun 2022, Articles 20-22). Candidates must receive an explicit, bilingual (ID/EN) privacy notice and record timestamped consent before hardware capture begins.

3. Strict Multi-Tenant B2B Isolation: In enterprise SaaS recruitment, cross-tenant Insecure Direct Object Reference (IDOR) leakage of candidate portfolios or assessor overrides is a critical trust and compliance failure.

2. Problem & Gap Analysis: P0-P3 Findings & Seam Audit (Step 3)

We audited both api/ and web/ end-to-end, separating Defective Implementations (code that fails its intended design) from Missing Specifications (unaddressed product/regulatory edge cases) and tracing every api/ <-> web/ contract seam.

ID / Tier	Issue & Layer	Classification	Root Cause & User/System Impact
P0-1 (P0)	Fit/Gap expected_level vs required_level Seam (FitGap::Engine <-> ComparisonTable.tsx)	Defective Implementation	Backend emitted expected_level while frontend read c.required_level, rendering "Lundefined" across the Required column and hiding Assessor Override indicators.
P0-2 (P0)	Portfolio Polling Deadlock on pending Status (PortfoliosController#show <-> PortfolioPage.tsx)	Defective Implementation	Portfolios start in generation_status: "pending" while Sidekiq queues generation. Controller only returned 202 Accepted for "generating?", returning an empty 200 OK payload on "pending" and halting frontend polling.

ID / Tier	Issue & Layer	Classification	Root Cause & User/System Impact
P0-3 (P0)	Missing UU PDP No. 27/2022 Consent Gate (sessions DB, SessionsController, InterviewPage.tsx)	Missing Specification	Candidates entered camera/mic capture and AI profiling without informed consent or database audit trail (consent_given_at, consent_version).
P0-4 (P0)	Multi-Tenant IDOR on Portfolios & Overrides (PortfoliosController, PortfolioSkillsController)	Defective Implementation	set_portfolio and set_portfolio_skill queried Portfolio/PortfolioSkill without joining Session on current_tenant_id, allowing cross-tenant read/override.
P0-5 (P0)	Silent Fabrication of L1 Ratings for Unprobed Skills (Portfolios::Generator, PortfolioPage.tsx)	Missing Spec & Defective Impl.	Unprobed skills (state: not_yet, probe_count: 0) or 0-turn sessions could receive fabricated L1 ratings instead of being separated as unassessed_skills.
P0-6 (P0)	Ruby 4.0 LoadError on ostruct in Auth (AuthorizeApiRequest)	Defective Implementation	Ruby 4.0 removed ostruct from default gems, causing require "ostruct" in AuthorizeApiRequest to fail on authenticated endpoints. Replaced with native Struct.
P1-1 (P1)	Destructive Portfolio Regeneration Wipe (Portfolios::Generator#save_skills)	Defective Implementation	portfolio_skills.destroy_all ran outside a transaction and cascaded deletion to assessor_overrides, wiping human assessor overrides on regeneration.
P1-2 (P1)	Cross-Language Fit/Gap False Missing (FitGap::Engine#find_portfolio_skill)	Defective Implementation	Matched skills only by skill_label string instead of canonical skill_id, failing when Assessment was in Indonesian and Vacancy in English.
P1-3 (P1)	WebSocket Binary Frame & Reconnect Timer Race (AudioWebSocketMiddleware, AudioRingBuffer)	Defective Implementation	Binary PCM arrays hit JSON.parse; browser refresh left old socket's 120s graceful_end_timer active; AudioRingBuffer lacked write/empty?/drain for Gemini replay.
P1-4 (P1)	Candidate Invite URL Port Mismatch (Session#invite_url)	Defective Implementation	Generated invite link using BACKEND_BASE_URL (port 3001) instead of FRONTEND_BASE_URL (port 5173/interview/:token).
P1-5 (P1)	Client-Only Interview Timer Reset on Refresh (SessionsController, InterviewTimer.tsx)	Defective Implementation	Timer counted down from timeLimitMin * 60 in local state without anchoring to server started_at.
P1-6 (P1)	Async-Only system_prompt Race & Silent Delete Failures (Assessments/VacanciesController)	Defective Implementation	Immediate session start raced Sidekiq prompt worker; destroy actions ignored restrict_with_error boolean return values.
P2-1 (P2)	Cloudflare Speed Test Firewall Block & CSP (internetSpeedTest.ts, vercel.json)	Defective Implementation	Blocked speed.cloudflare.com hard-failed hardware check; vercel.json blocked camera=() and omitted speed.cloudflare.com from CSP.
P2-2 (P2)	Prawn PDF Crash on Unicode Punctuation (Exports::PdfGenerator)	Defective Implementation	Helvetica WinAnsiEncoding crashed on arrows (->) and em-dashes (---) in AI summaries/transcripts.
P3-1 (P3)	Form Validation & LiveMonitor Truncation (AssessmentEdit, VacancyEdit, LiveMonitorPage)	Defective Implementation	Allowed 0-skill or duplicate-skill saves; LiveMonitorPage truncated transcript to last 10 turns (.slice(-10)) and lacked HTTP coverage fallback.

2.1 Constraint Signal Analysis (In-Scope vs. Intentionally Scoped Out)

In-Scope for this Revamp: All P0-P3 items above (multi-tenant security, api/ <-> web/ contract normalization, UU PDP consent gate, unassessed skill separation, override preservation, WebSocket binary/reconnect resilience, and server-anchored timers). Intentionally Scoped Out: Full PostgreSQL Row-Level Security (RLS) migration across shared legacy rakamin-api tables, dedicated WebRTC TURN relay infrastructure, and custom CJK TTF font embedding in Prawn.

3. Revamp Strategy, Self-Defined Acceptance Criteria & Trade-offs (Step 4)

3.1 Self-Defined Acceptance Criteria (AC-1 to AC-8)

- AC-1 (Fit/Gap Contract & Canonical Matching): FitGap::Engine emits both expected_level and required_level, ai_level, and is_override. ComparisonTable.tsx renders L1-L5 labels and Assessor Override badges without Lundefined. Matching prioritizes case-insensitive skill_id before skill_label.

- AC-2 (Zero Fabricated L1s for Unassessed Skills): 0-turn sessions produce 0 PortfolioSkill rows. Skills with state == "not_yet", probe_count == 0, and no transcript evidence are excluded from portfolio_skills and returned in unassessed_skills, rendered in a dedicated "Unassessed Skills (Not Evaluated)" section.

- AC-3 (Resilient Portfolio Polling & Atomic Regeneration): GET /api/v1/sessions/:id/portfolio returns 202 Accepted ({ status: "generating" }) for both pending and generating states. Regeneration runs inside ActiveRecord::Base.transaction and restores existing AssessorOverride records.

- AC-4 (UU PDP No. 27/2022 Informed Consent): Candidates must accept the bilingual (ID/EN) UU PDP privacy & AI voice recording notice on InterviewPage.tsx before hardware checks start, persisting consent_given_at and consent_version via POST /api/v1/sessions/:token/consent.

- AC-5 (Multi-Tenant IDOR Prevention): PortfoliosController and PortfolioSkillsController scope all lookups via Session with sessions: { tenant_id: current_tenant_id }, returning 404 Not Found on cross-tenant access.

- AC-6 (WebSocket Reconnect & Server-Anchored Timer): ACTIVE_CONNECTIONS registry cancels stale 120s graceful_end_timer on candidate reconnect; AudioRingBuffer supports write/empty?/drain for Gemini audio replay; InterviewTimer.tsx anchors countdown to server started_at.

- AC-7 (Synchronous Prompt Compilation & Cache Invalidation): AssessmentsController compiles system_prompt synchronously on create/update; VacanciesController invalidates stale FitGapReport caches when vacancy skills change.

- AC-8 (Graceful Network Fallback & PDF Encoding Safety): internetSpeedTest.ts falls back to API latency measurement if speed.cloudflare.com is blocked; Exports::PdfGenerator sanitizes non-WinAnsi characters before Prawn rendering.

3.2 Key Architectural Trade-offs (Option A vs. Option B)

Trade-off 1 - Unassessed Skills Representation: Option A was dropping the NOT NULL and CHECK (1..5) constraints on portfolio_skills.ai_level to store unprobed skills with nil levels. Option B (Chosen) keeps portfolio_skills strictly for evaluated skills (1..5) and derives unassessed_skills dynamically in PortfoliosController by diffing session.coverage_maps.configured against portfolio.portfolio_skills. This preserves database integrity and prevents downstream average-score distortion.

Trade-off 2 - Fit/Gap Field Normalization: Option A was changing only ComparisonTable.tsx to read expected_level. Option B (Chosen - Dual-Key Normalization) emits both expected_level and required_level in FitGap::Engine, normalizes existing cached JSONB rows in PortfoliosController#fit_gap_json, and updates ComparisonTable.tsx to c.required_level ?? c.expected_level. This guarantees zero-downtime backward compatibility with already-persisted FitGapReport records.

4. Monozukuri Implementation, Automated Tests & Verification Proof (Step 5)

4.1 Automated Test Suite Execution (100% Passing)

1. Backend RSpec Suite (bundle exec rspec --format documentation): 16 examples, 0 failures across 4 spec files: spec/lib/audio_ring_buffer_spec.rb (3 examples), spec/services/fit_gap/engine_spec.rb (2 examples), spec/services/portfolios/generator_spec.rb (3 examples), and spec/requests/api/v1/multi_tenant_and_session_lifecycle_spec.rb (8 examples).

2. Frontend Build & Automated Contract Tests (npm run build & npm test): tsc && vite build succeeded with 0 errors (1841 modules transformed); node --test tests/frontend_contracts.test.mjs passed 4/4 tests (0 failures).

4.2 Seeded Fault Test Proof (Branch: test/seeded-fault-proof)

To prove our automated tests genuinely guard business logic and are not tautological, we created branch test/seeded-fault-proof and intentionally injected a fault in FitGap::Engine#find_portfolio_skill (ignoring canonical skill_id and matching only by skill_label). Running bundle exec rspec spec/services/fit_gap/engine_spec.rb immediately caught the regression:

```
1) FitGap::Engine#call matches skills by canonical skill_id across languages (FAILED - 1)
Failure/Error: expect(sys_design_comp["result"]).to eq("match")
expected: "match", got: "not_assessed"  (2 examples, 1 failure)
```

The seeded fault was committed as 724d4ff and cleanly reverted in eefc5ac on branch test/seeded-fault-proof so the Git history visibly documents both the fault injection and its revert.

4.3 AI Verification Moment (Critical Verification of AI-Generated Code)

1. AudioRingBuffer Interface & Return-Type Verification: When wiring AudioWebSocketMiddleware#replay_buffered_audio and #handle_browser_audio, initial AI-generated code called .write(data), .empty?, and .drain on AudioRingBuffer and assumed .drain returned an Array of chunks. By inspecting api/app/lib/audio_ring_buffer.rb and Gemini::LiveClient#send_audio, we discovered that (a) AudioRingBuffer originally only defined #push, #since, #size, #count, and #clear (which would have raised NoMethodError on Gemini reconnect), and (b) send_audio expects a concatenated binary String (@chunks.map(&:data).join), not an Array.

2. Ruby 4.0 ostruct Removal Caught by Request Specs: Running our RSpec request specs immediately uncovered LoadError: cannot load such file -- ostruct in app/auth/authorize_api_request.rb:3 because Ruby 4.0 removed ostruct from default gems. Replacing OpenStruct.new with a native Ruby Struct (UserPrincipal = Struct.new(:id, :role, :scheme, keyword_init: true)) eliminated the external gem dependency and restored all authenticated API endpoints.